

IT-sikkerhed

for 3 sem.

PENETRATION
TEST

Sune Andersen (SUAN@)



I dag :

AI-sikkerhed og **prompt injection** (video)

Kali Linux og grundlæggende Linux (Ubuntu /debian)

Forskellige scan tools : Recon, Nmap, Nikto, WPScan,

Pentest, scope og skriftlig tilladelse

Dokumentation af sikkerhedsfund (openVAS)

HomeLab/Dojo og sikker netværksopsætning
+Live Demo af lab øvelse



Kali er Ubuntu / Debian med lidt ekstra ;-)

Debian-baseret Linux – samme grundlæggende principper som andre Debian-systemer.

APT & pakkehåndtering – installer, opdater og administrér software på klassisk Linux-manér.

Kommando-linjen er central – Bash, scripting og standard Linux-værktøjer er fundamentet.

Security-værktøjer inkluderet – scanning, analyse, pentesting, forensics og OSINT.

Kan tilpasses – installer kun de værktøjer og services, du faktisk har brug for.

Kali = værktøjskasse – værktøjerne er kun så gode som den forståelse, du bruger dem med.

Læringsbudskab: Lær Linux, netværk og principperne bag værktøjerne – ikke bare hvilke knapper du skal trykke på.



HomeLab/Dojo og sikker netværksopsætning



Isoleret miljø – test og eksperimenter uden at påvirke det primære netværk.

Realistisk træningsmiljø – mulighed for at simulere angreb, teste hardening og øve incident response.

Dokumentation – hold styr på topologi, IP-plan, services og ændringer.

Formål: Et kontrolleret og sikkert miljø, hvor man kan lære, teste og eksperimentere uden at kompromittere det øvrige netværk (skolens / eget).

Se Moodle forløbet for download steder ;-)

NB! Kali er Ubuntu / Debian med lidt ekstra ;-)



Forskellige scan tools....

Recon – indsamling af information om et mål: domæner, IP-adresser, DNS, services og angrebsflade.

Nmap – kortlægning af netværk og services: hosts, åbne porte, service-versioner og OS-detektion.

Nikto – webserver-scanning med fokus på kendte problemer, usikre konfigurationer og interessante filer.

WPScan – specialiseret scanning af **WordPress**: plugins, themes, brugere og kendte sårbarheder.



Pentest, scope og skriftlig tilladelse

Pentest = kontrolleret sikkerhedstest – formålet er at identificere og dokumentere sikkerhedsproblemer.

Scope – præcisér *hvad* der må testes: IP-adresser, domæner, systemer, applikationer og tidsrum.

Regler for engagementet – aftal hvilke teknikker der må anvendes, og hvad der er uden for scope.

Skriftlig tilladelse – få eksplicit godkendelse fra den system-/dataansvarlige **før testen starter**.

Dokumentér alt – scope, tilladelse, fund, testtidspunkter og eventuelle ændringer.

Stop ved tvivl – hvis et system viser sig at ligge uden for scope, -så stop og afklar situationen.

Læringsbudskab: Et godt pentest handler ikke kun om teknik.

Du skal vide, hvad du må teste, hvor du må teste, og hvorfor du tester det.



Dokumentation af sikkerhedsfund – OpenVAS

- **OpenVAS** – scanner systemer for kendte sårbarheder og fejlkonfigurationer.
- **Dokumentér fundet** – hvad er problemet, hvor er det fundet, og hvilken service/version er berørt?
- **Severity & risiko** – vurder alvoren og den potentielle påvirkning af systemet.
- **Evidens** – gem relevante scan-resultater, versioner, timestamps og screenshots.
- **Valider fund** – et automatisk scan er et udgangspunkt; kontrollér om fundet faktisk er relevant.
- **Anbefaling** – beskriv en konkret løsning: patch, konfigurationsændring, segmentering eller anden mitigering.
- **Opfølgning** – scan igen efter udbedring og dokumentér, at problemet er løst.

Læringsbudskab:

Et sikkerhedsfund er først værdifuldt, når det kan **forstås, dokumenteres, prioriteres og følges til dørs**.



HomeLab/Dojo og sikker netværksopsætning

Isoleret labmiljø – et sikkert sted at teste, fejle og lære.

Netværkssegmentering – adskil lab, klienter, servere og øvrige systemer.

Firewall & adgangskontrol – begræns kommunikation til det nødvendige.

Monitoring & logging – se hvad der sker på netværket og lær af trafikken.

Kali + værktøjer – brug scannerne til at undersøge og forstå dit eget miljø.

Fra teori til praksis – recon → scanning → analyse → dokumentation → remediation.

-> Live Demo – labøvelse (dagens opgave!)

Vi går fra et ukendt system til et dokumenteret sikkerhedsfund.

Læringsbudskab: Det er i home-lab, vi omsætter teori til praktiske færdigheder
– sikkert, kontrolleret og med dokumentation hele vejen.



Nysgerrig?
Spørg løs!



Min Mail
suan@zealand.dk